CNOVI PROGRAMACIÓN WAP

Reporte laboratorio #9: File path traversal Traversal sequences stripped non-recursively



Lizeth Infante Martínez

Reporte de Laboratorio: File path traversal Traversal sequences stripped non-recursively

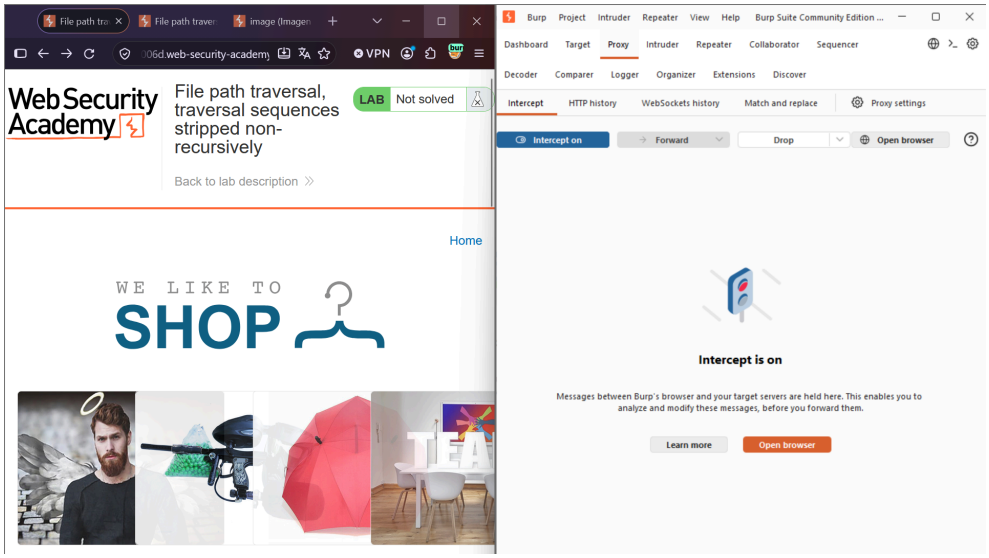
1. Objetivo

Demostrar la vulnerabilidad de salto de directorio cuando las secuencias de navegación son eliminadas de forma no recursiva (non-recursively) por la aplicación web. Se utiliza Burp Suite para interceptar, modificar el parámetro filename con secuencias anidadas y reenviar la petición con el fin de evadir el filtro y acceder al archivo restringido del servidor (/etc/passwd).

2. Metodología y Pasos de Resolución

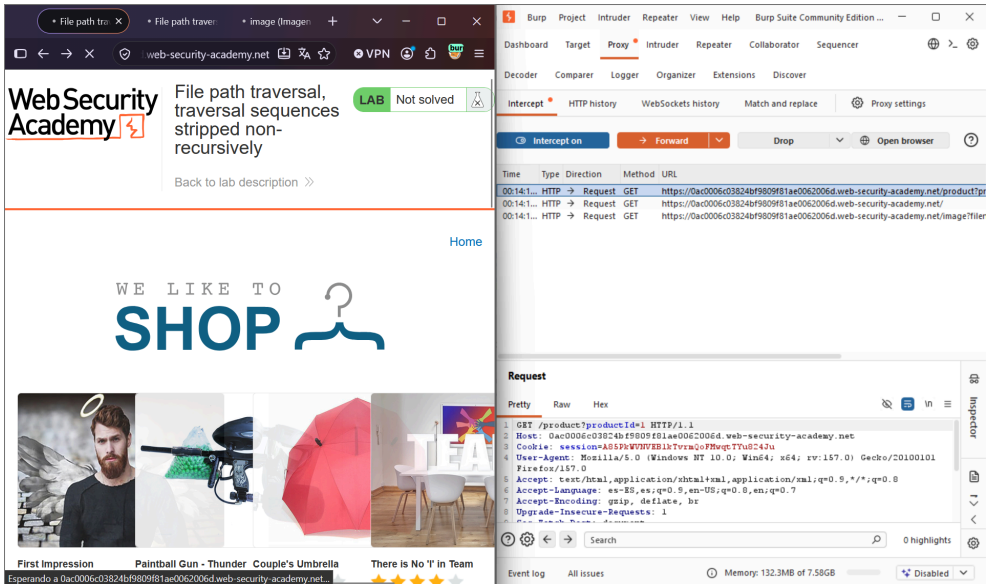
Paso 1: Configurar la intercepción en Burp Suite

- Ve a la pestaña Proxy en Burp Suite y asegúrate de que el botón indique Intercept on (Interceptación activada).



Paso 2: Generar la petición de una imagen de producto

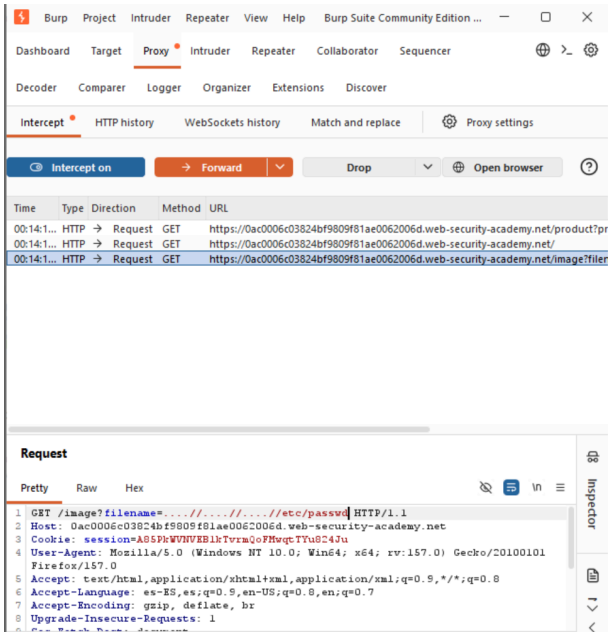
- Dirígete a la ventana del navegador integrada en Burp o a tu navegador configurado con el proxy.
- Haz clic en cualquiera de los productos de la tienda para ver los detalles o cargar una imagen y generar la solicitud HTTP correspondiente.



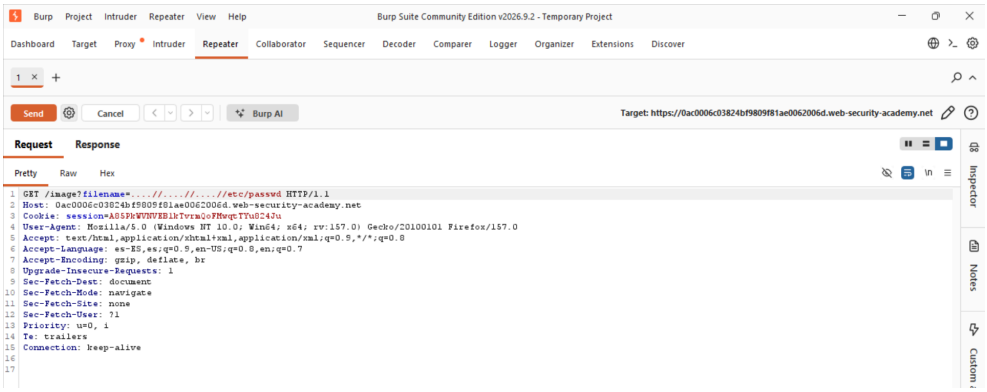
Paso 3: Interceptar, modificar la solicitud y usar el Repeater

- En la misma pestaña de intercept en el área de abajo en los request al darle click a una de las peticiones podrás ver parte del código de la petición, desde ahi podras modificarla para que en área del "filename" se divise de la siguiente forma

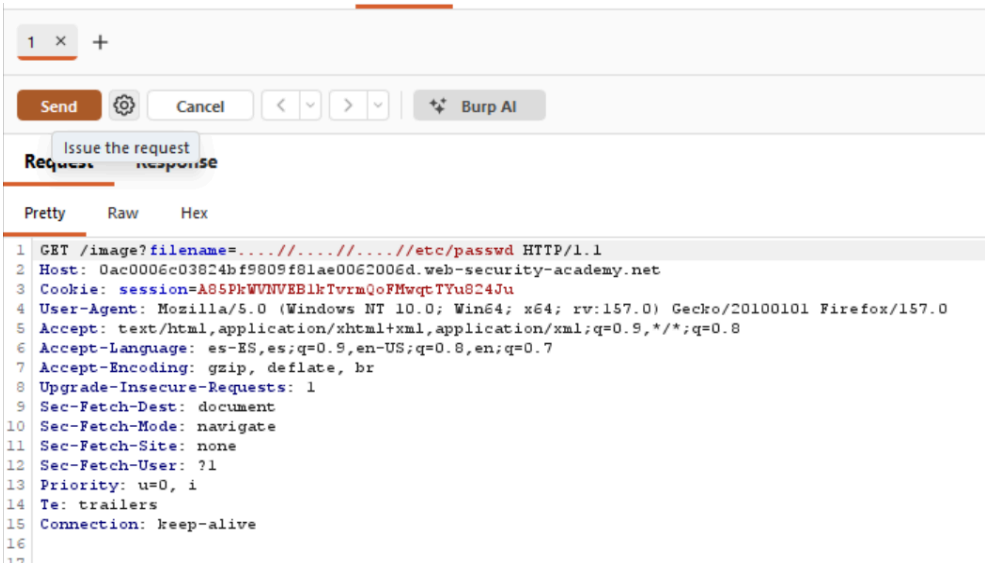
GET /image?filename=....//....//....//etc/passwd HTTP/1.1



- Da click derecho al codigo modificado y mandalo al "send and repeater".

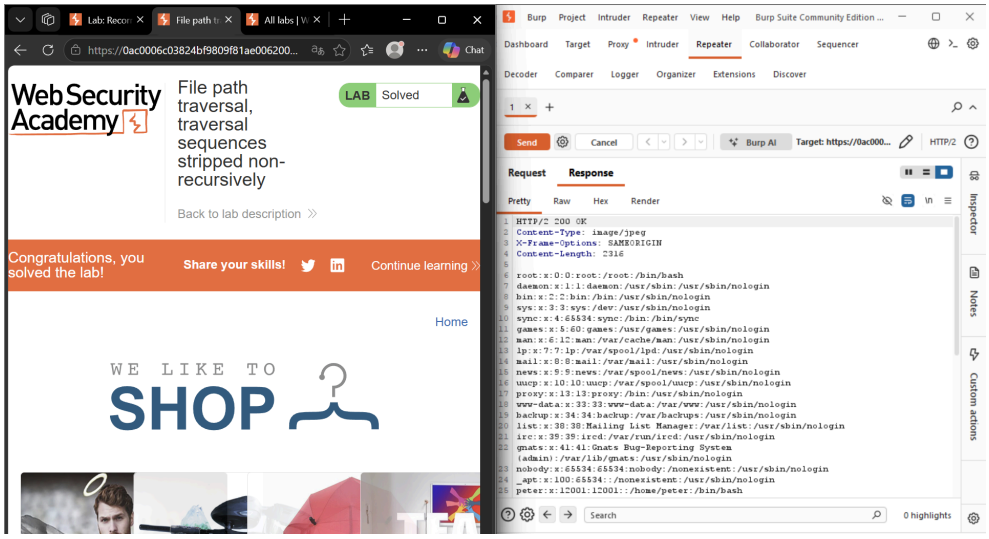


- Desde ahí haz clic en el botón Send en la esquina superior izquierda de la pestaña Repeater para emitir la solicitud.



3. Verificación y Resultados

- **Panel de Respuesta (Repeater):** Al enviar la petición modificada, revisa el panel de respuesta (Response). Se observa el código de estado 200 OK y el contenido completo del archivo /etc/passwd (líneas de texto que comienzan con usuarios como root:x:0:0..., daemon:x:1:1..., etc.), lo que confirma que la evasión del filtro y la explotación fueron exitosas.



- **Navegador:** Al comprobar el estado en el navegador del laboratorio, se visualiza la notificación de que el reto ha sido completado satisfactoriamente (Congratulations, you solved the lab!).

